

Reconstitution de l'attaque

Vecteur d'intrusion, chronologie et hypothèses d'entrée physique

AtlasGrid — Cellule 5
Cellule d'investigation, Forensic — Acte I

23 septembre 2026

Ce document reprend les verdicts déjà posés dans la fiche de traçabilité de la cellule (A-11, A-01, A-19, A-02, A-17, A-05) et le bilan du fil SOC, afin de ne pas produire une lecture concurrente des mêmes preuves. Son apport propre porte sur les deux pistes encore sans fiche : le badge et la caméra.

1 Frise chronologique

Survenue donne l'horodatage technique de l'événement (journal ou en-tête) — le moment où la chose s'est réellement produite. *Signalée* donne le moment où la cellule en a pris connaissance ; un tiret signifie que les deux coïncident (signal reçu en direct, sans délai). *Statut* reflète la qualification retenue au terme du dossier disponible à ce jour : **Fait** (établi par une pièce datée), **Bruit** (verdict de la fiche de traçabilité), **Hypothèse** (non vérifiable en l'état) ou **À qualifier** (signal reçu, non encore tranché).

1.1 Vue d'ensemble — J-21 à J-1

Survenue	Signalée	Événement	Statut
J-21 → J-1 (×8, ~02h-05h)	14h27	Connexions VPN nocturnes, sans MFA (A-02)	Fait
J-3, 01h12	16h22	Politique de rétention Veeam modifiée par <code>svc_oasisnet</code> (A-05)	Fait

1.2 Fenêtre critique — J-1, 02h00 à J1, 17h24

Survenue	Signalée	Événement	Statut
02h00–04h00	15h37	Badge stagiaire IT, salle des serveurs	Hypothèse
02h15–04h35	14h27	Dernière session VPN <code>svc_oasisnet</code> (A-02)	Fait
03h12	11h52	Exécution de <code>Mirage.A</code> sur FIN-112 (A-01)	Fait
03h13	11h52	Chiffrement de masse détecté (A-01)	Fait
03h14	11h52	C2 bloqué puis contourné (A-01)	Fait
03h15	11h52 / 16h22	EDR désactivé (<code>admin_local</code> , A-01) et <code>vssadmin delete shadows</code> (A-05) — étiquetées J-1 et J1 respectivement pour la même minute, voir section 10	Fait
17h20–17h24 (J-1)	16h02	USB « PAIE-SAUVÉ », service paie, la veille au soir (A-17)	Bruit
06h41 (J1)	11h17	Email de hameçonnage reçu — après l'infection (A-11)	Fait
11h32	—	Vague de tickets inhabituelle (lenteurs, partages, impressions), plusieurs services	À qualifier
J-3	12h32	USB trouvée sur le parking	Bruit
14h47	—	Fichiers du partage comptable renommés en <code>.mirage</code> , propagation en cours	Fait
15h15	—	Export du journal Veeam généré	Fait
15h22	—	Mail « Migration Exchange » signalé	À qualifier
15h28	16h22	Dépôts BKP-01 et BKP-02 injoignables (A-05)	Fait
16h54	—	A-20 confirme le mail légitime (FP-8)	Fait

2 Vecteur confirmé — accès distant OasisNet

```

=== FortiGate SSL-VPN · export du journal d'événements (39426) ===
Équipement : FGT-RBT-01   Généré : J1 13:10   filtre : user=svc_oasisnet

date   plage horaire   utilisateur   src_ip   mfa   octets_sortants
J-21   02:04-04:52   svc_oasisnet  196.200.114.41   non   1,2 Go
J-19   02:11-03:58   svc_oasisnet  196.200.114.41   non   0,8 Go
J-16   02:22-04:39   svc_oasisnet  102.118.53.17   non   1,4 Go
J-14   01:57-04:20   svc_oasisnet  102.118.53.17   non   1,6 Go
J-11   02:03-04:41   svc_oasisnet  102.118.53.17   non   1,7 Go
J-9    02:30-05:01   svc_oasisnet  102.118.53.17   non   2,1 Go
J-4    02:12-04:44   svc_oasisnet  102.118.53.17   non   1,9 Go
J-1    02:15-04:35   svc_oasisnet  102.118.53.17   non   1,8 Go

--- profil de référence (AD / RH) ---
svc_oasisnet : heures ouvrées 09:00-18:00, mfa=requis, src=plages OasisNet
géoIP(196.200.114.41 / 102.118.53.17) : hors du pays d'exploitation habituel

AtlasGrid · pièce d'exercice · ne pas copier-coller

```

FIGURE 1 – A-02 — FortiGate SSL-VPN, journal d'événements filtré sur `svc_oasisnet`.

2.1 Le même compte a neutralisé les sauvegardes



3

2.2 Le phishing : réel, mais un vecteur à part

```
--- Proofpoint · en-têtes bruts du message (RFC 5322) ---
Message-ID : <4f9cle...@atlasgrid-it.info>   Mise en quarantaine : oui

Return-Path : <support-messagerie@atlasgrid-it.info>
Received : from mail.atlasgrid-it.info (193.42.55.108)
    by mx.atlasgrid.ma; [J1] 06:41:22 +0100
Authentication-Results : mx.atlasgrid.ma:
    spf=fail (IP émettrice 193.42.55.108 non autorisée) ;
    dkim=none (aucune signature) ;
    dmarc=fail (p=none) header.from=atlasgrid-it.info
From : "Support Messagerie" <support-messagerie@atlasgrid-it.info>
To : direction.financiere@atlasgrid.ma
Subject : Migration de votre messagerie · action requise avant ce soir
X-Mailer : PHPMailer 6.1
--- corps (extrait) ---
« Votre boîte sera suspendue ce soir. Revalidez vos identifiants : »
!xxps://atlasgrid-it[.]info/owa/login [T1566.002]

AtlasGrid · pièce d'exercice · ne pas copier-coller
```

FIGURE 3 – A-11 — en-têtes bruts du courriel de hameçonnage (Proofpoint).

Ce que la pièce établit. Les trois contrôles d'authentification échouent ensemble (`spf=fail`, `dkim=none`, `dmarc=fail`) et le domaine expéditeur `atlasgrid-it.info` imite le domaine réel. Ces éléments confirment le hameçonnage lui-même ; ils ne disent rien de son lien avec FIN-112, dont l'infection lui est antérieure.

```
--- Microsoft Defender for Endpoint · export d'alertes ---
Tenant : atlasgrid.onmicrosoft.com   Généré : J1 10:05 (UTC)
Requête : DeviceName in (FIN-112, RH-031) | order by Timestamp asc

Horodatage(UTC)  Poste  Menace                               Sév.  Action
[J-42] 11:02:47  RH-031  PUA:Win32/Toolbar.Gen                Bas   Nettoyée
[J-42] 11:05:13  RH-031  PUA:Win32/Toolbar.Gen                Bas   Nettoyée
[J-35] 09:14:02  RH-031  PUA:Win32/Toolbar.Gen                Bas   Nettoyée
[J-1] 03:12:09   FIN-112  Ransom:Win32/Mirage.A                HAUT  QUARANTAINE ÉCHOUÉE
    Fichier = C:\Windows\svchost32.exe
    SHA256 = 3f9a4b1e9c2d7a5f0b8e6d41a97c...e0c71e
    Signature = ABSENTE (binaire non signé)  Détection = ML.HighConfidence
[J-1] 03:13:55   FIN-112  Behavior:Win32/MassFileWrite          HAUT  Détectée
[J-1] 03:14:31   FIN-112  Blocage sortant -> 45.137.184.62:443 (contourné)
[J-1] 03:15:22   FIN-112  Altération : protection temps réel désactivée
    acteur=admin_local technique [T1562.001]

--- fin de l'export (6 alertes) ---

AtlasGrid · pièce d'exercice · ne pas copier-coller
```

FIGURE 4 – A-01 — journal EDR / antivirus, poste FIN-112 (Microsoft Defender for Endpoint).

Ce que la pièce établit. La séquence 03h12–03h15 se lit comme un enchaînement piloté et non comme un malware livré à lui-même : détection puis quarantaine échouée, chiffrement de masse une minute plus tard, puis désactivation de la protection depuis un compte `admin_local`. C'est cette

dernière ligne qui distingue une intrusion active d'un incident purement automatisé.

2.3 Décision : isolement de FIN-112

Sur la base de A-01, le SOC a identifié FIN-112 comme le poste patient zéro, encore allumé et connecté au réseau. La cellule a choisi de l'isoler du réseau sans l'éteindre, plutôt que de couper l'alimentation ou de le laisser connecté pour observer l'attaquant.

L'équipe Forensic a validé ce choix dans le fil : « débranché du réseau mais laissé allumé, on coupe la propagation tout en préservant la mémoire vive. Je peux encore capturer les processus actifs et les connexions C2 avant qu'elles ne s'effacent. C'est le bon geste. » Couper l'alimentation aurait effacé la session de commande et de contrôle que A-01 montre encore active (45.137.184.62:443) au moment de l'isolement.

2.4 Le second mail : vérifié légitime

Le service informatique a soumis ce courriel à la cellule avec une question ouverte — « authentique ou pas ? » — après que quatre utilisateurs l'ont signalé comme suspect. La pièce A-20 tranche cette question.

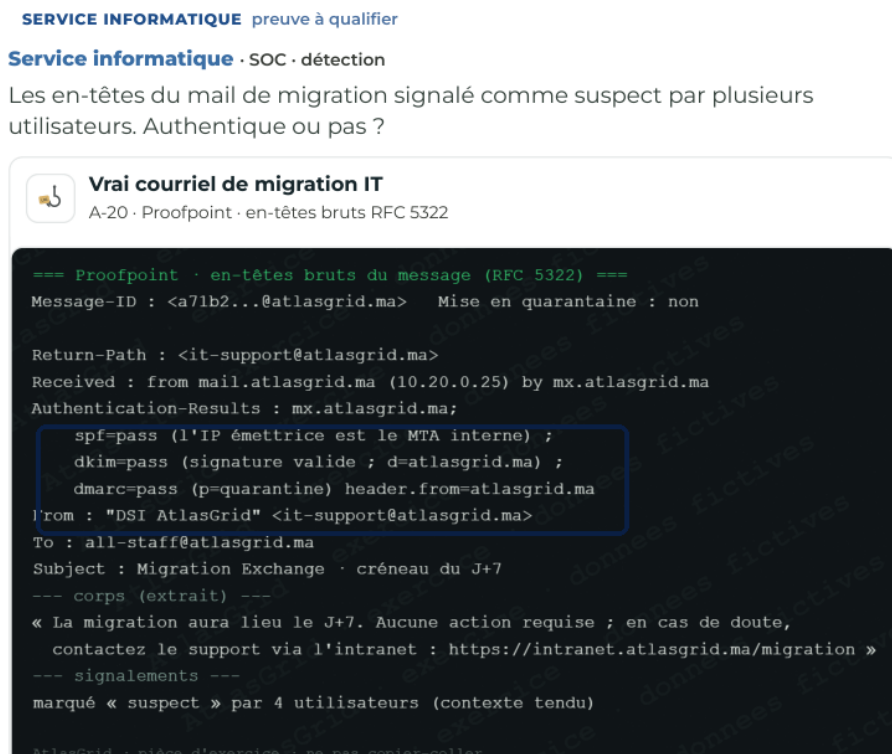


FIGURE 5 – A-20 — Service informatique (SOC), demande de qualification, et en-têtes bruts du courriel réel de migration IT (Proofpoint).

Ce que la pièce établit. Les trois contrôles d'authentification passent cette fois ensemble, depuis le MTA interne `atlasgrid.ma`. Ce résultat confirme la conclusion du DSI (FP-8, écartée) : ce message n'a aucun rapport avec A-11.

3 Correction de lecture

L'en-tête du courriel de hameçonnage (A-11) porte un horodatage de réception à 06h41 le lendemain matin. Le journal EDR (A-01) situe l'exécution du rançongiciel sur FIN-112 à 03h12, plus de trois heures avant. L'email ne peut donc pas être le vecteur initial de l'infection de ce poste : il lui est postérieur.

Ce constat, déjà relevé dans la fiche de traçabilité de l'équipe, est confirmé par le bilan du fil SOC à 15h22 : le journal VPN change la lecture de la matinée et fait du compte `svc_oasisnet`, actif depuis J-21, le point d'entrée antérieur au phishing. Le courriel reste un événement réel — un mot de passe a été saisi — mais rien n'établit qu'il soit à l'origine de l'infection de FIN-112.

Un employé de la direction financière a confirmé, à 12h17, avoir saisi ses identifiants sur ce courriel, en précisant les avoir saisis « hier soir ». Cette indication verbale ne coïncide pas avec l'horodatage technique de réception de A-11 (06h41, le matin même). Le dossier reçu ne permet pas de trancher cet écart — imprécision du témoignage ou fuseau horaire du client de messagerie — et il est donc signalé tel quel plutôt que lissé.

4 Affirmations contredites par les preuves

Deux messages internes minimisent l'incident avant que les pièces ne soient toutes qualifiées. Aucun des deux ne résiste à ce qui est déjà retenu preuve au moment où il est émis.

OasisNet, prestataire d'infogérance. Le message invoque une « maintenance planifiée [qui] s'est mal terminée ce week-end » et affirme que « rien n'indique que cela [les] concerne directement ». Le journal A-02, qualifié preuve, montre pourtant huit connexions nocturnes du compte du prestataire, sans MFA, depuis J-21 — un pattern que ce message ne mentionne pas et qu'il précède dans le fil.

Karim Bennis, Directeur des SI. À 12h52 — soit une heure après que le journal EDR (A-01) a été retenu preuve, et avant que le journal VPN (A-02) ne le soit à son tour — il qualifie la situation d'« incident d'exploitation banal ». A-01 situait pourtant déjà l'exécution d'un rançongiciel sur FIN-112, avec désactivation délibérée des défenses depuis un compte `admin_local`.

Les deux messages sont tracés dans le fil comme « à recouper » : ce sont des déclarations, pas des constats, et les pièces déjà qualifiées les contredisent directement.

5 Hypothèses d'entrée physique

5.1 Clé USB abandonnée sur le parking visiteurs (A-19)

Statut : bruit (FP-7 écartée), verdict de la fiche de traçabilité. L'employé qui l'a trouvée ne l'a jamais branchée. L'analyse en bac à sable confirme qu'elle est réellement piégée — elle lance un faux `HelpDesk.exe` — mais le journal DLP ne montre aucune insertion sur un poste du domaine.

La distinction avec une fausse piste mérite d'être posée : une fausse piste oriente l'enquête vers une mauvaise conclusion, alors que cet artefact se réfute lui-même dès que le DLP est consulté. Il n'a jamais eu l'occasion d'agir sur le système d'information. Une limite subsiste : le DLP ne couvre que les hôtes du domaine, pas un appareil personnel.

5.2 Clé USB « PAIE-SAUVÉ » (A-17)

```
=== DLP poste de travail - export des périphériques amovibles ===
hôte : PAIE-STA-3   Généré : J1 (sur demande)

_time      périphérique  action  fichier      taille
J-1 17:20  USB 'PAIE-SAUVÉ'  montage -
J-1 17:21  USB 'PAIE-SAUVÉ'  copie  bulletins_mois.zip  44 Mo (AES)
J-1 17:24  USB 'PAIE-SAUVÉ'  éjection -

--- contexte ---
utilisateur : gestionnaire de paie (session nominative + badge)
autorisation : ticket #4471 « sauvegarde manuelle avant clôture »
horaire : heures ouvrées (17:20), hors de la fenêtre nocturne
volume : 44 Mo (à comparer aux 117,8 Go de l'exfiltration nocturne A-03)
destination : clé USB locale, aucune sortie réseau

AtlasGrid - pièce d'exercice - ne pas copier-coller
```

FIGURE 6 – A-17 — DLP endpoint, journal des périphériques amovibles, poste PAIE-STA-3.

Statut : bruit, à confirmer. Le bloc « contexte » de l'export porte l'essentiel de la justification : ticket #4471, session nominative, copie en heures ouvrées (17h20, hors de la fenêtre nocturne où se joue le reste de l'incident), pour un volume de 44 Mo contre 117,8 Go pour l'exfiltration nocturne relevée en A-03. Le RSSI demande néanmoins de ne pas écarter ce constat trop vite : un faux positif se justifie, il ne s'auto-déclare pas.

5.3 Badge du stagiaire IT (A-14, en attente)



FIGURE 7 – Signalement de la DRH — anomalie de badge, référence A-14 annoncée.

1. Identification. La référence A-14 a été annoncée par la DRH mais jamais transmise à la cellule. Ce qui existe à ce jour n'est pas un export du système de contrôle d'accès, seulement un signalement narratif.

2. Capture. La seule pièce disponible est le message de la DRH ci-dessus, daté de 15h37. Aucun export brut de badgeuse ne l'accompagne.

3. Indicateurs. Le message donne une plage horaire (02h–04h), une zone (salle des serveurs) et une personne visée. Il ne donne ni identifiant de badge, ni porte précise, ni preuve que le badge physique en cause n'a pas été cloné ou emprunté. Cette fenêtre recouvre exactement la session VPN A-02 et l'exécution EDR sur FIN-112, sans que ce recoupement établisse un lien causal.

4. Justification du verdict. Aucun des trois verdicts (preuve, fausse piste, bruit) n'est applicable en l'absence d'un artefact vérifiable. « Non confirmée » traduit un vide d'information, pas une conclusion.

5. Actions recommandées. Demander à Yassine l'export complet de la badgeuse pour la nuit J-1 ; comparer avec la liste des badges valides ce soir-là ; ne pas interroger le stagiaire hors procédure RH tant que le journal n'est pas en main, conformément à la demande explicite de la DRH.

5.4 Caméra — coupure ou angle mort

1–3. Aucune référence n'a été attribuée, aucune pièce n'a été transmise, et il n'y a donc rien à analyser à ce stade — à la différence des trois pistes précédentes, qui disposent chacune d'au moins un document à qualifier.

4. Justification du verdict. Aucun verdict n'est possible : les trois qualifications supposent un artefact déjà en main. L'absence de pièce ne prouve ni une panne ni une entrée physique ; c'est un point aveugle à combler, non un fait à trancher.

5. Actions recommandées. Demander à Yassine le journal de vidéosurveillance de la salle des serveurs et l'état de fonctionnement des caméras pour la fenêtre 02h–04h de J-1, et le croiser avec le journal badge dès sa réception.

6 Hypothèses complémentaires

6.1 Identifiants svc_oasisnet volés côté OasisNet

Le compte compromis est celui du prestataire, pas d'AtlasGrid. Le point d'entrée le plus économique pour l'obtenir est donc chez OasisNet lui-même — phishing, fuite ou poste compromis côté prestataire — plutôt que chez AtlasGrid. Cette hypothèse est cohérente avec un usage qui démarre à J-21, avant tout signal observé côté AtlasGrid.

6.2 Compte orphelin, jamais désactivé

Un accès prestataire ancien, non révoqué, aurait pu être réutilisé sans qu'aucun vol n'intervienne. Le caractère régulier de l'usage, toutes les deux ou trois nuits, ressemble davantage à un usage actif qu'à un oubli dormant, sans que cela l'exclue formellement.

6.3 Vol de session plutôt que de mot de passe

Un jeton de session volé contournerait le contrôle MFA sans que le mot de passe lui-même soit compromis. Le journal A-02 montre l'absence de MFA sur les connexions ; il ne dit rien du mécanisme par lequel ce contrôle a été contourné.

6.4 Complicité interne

Un intermédiaire côté AtlasGrid aurait pu faciliter l'accès. Le compte utilisé reste toutefois celui du prestataire, et aucun indice du dossier ne pointe directement vers un employé d'AtlasGrid.

7 Degré de confiance par hypothèse

Hypothèse	%	Justification
Identifiants volés côté OasisNet	55	Compte prestataire ; l'usage démarre avant tout signal côté AtlasGrid.
Badge = présence physique liée	35	Fenêtre 02h–04h chevauche VPN et EDR ; vol, clonage ou prêt du badge non exclus.
Vol de session (contournement MFA)	20	Expliquerait l'absence de MFA ; ni confirmé ni exclu par A-02.
Compte orphelin non désactivé	15	Pattern trop régulier pour un simple oubli, sans exclusion formelle.
Complicité interne	10	Aucun indice direct ; le compte reste celui du prestataire.
USB PAIE-SAUVE liée à Mirage	8	Ticket, session et horaire cohérents ; volume dérisoire face à l'exfiltration nocturne.
USB parking, vecteur physique	2	DLP formellement négatif — vérifié, non supposé.
Caméra = entrée physique	—	Aucune donnée reçue ; pas de base pour chiffrer.

8 Synthèse

Phase	Statut	Appui
Accès initial	Fait	<code>svc_oasisnet</code> , sans MFA, actif depuis J-21 (A-02)
Sabotage des sauvegardes	Fait	Rétention modifiée à J-3, clichés supprimés à J1 03h15 (A-05)
Impact	Fait	<code>Mirage.A</code> , chiffrement, fichiers <code>.mirage</code> sur le partage, EDR désactivé (A-01)
Phishing → FIN-112	Hypothèse réfutée	Email reçu après l'infection (A-11 confronté à A-01)
Présence physique	Hypothèse ouverte	Badge non confirmé, caméra sans pièce

9 État des actifs

Le tableau ci-dessous ne reprend pas la cartographie de criticité produite pour la direction (12h00) : il ne recense que les actifs mentionnés dans les pièces analysées ici, avec leur état constaté au moment de la rédaction — ni plus, ni moins.

Actif	État	Appui
Compte <code>svc_oasisnet</code> (VPN OasisNet)	Compromis	Sans MFA depuis J-21, non révoqué à la rédaction (A-02)
FIN-112 (poste, direction financière)	Compromis, isolé	Débranché du réseau, laissé sous tension (A-01, décision de la cellule)
Partage comptable (direction financière)	Chiffrement actif	Propagation en cours, isolement partiel (signal 14h47)
Sauvegardes en ligne (VBR-01, BKP-01, BKP-02)	Neutralisées	Rétention modifiée, clichés supprimés, dépôts injoignables (A-05)
Sauvegarde hors ligne / immuable	Inconnu	Non vérifiée dans ce dossier — voir actions recommandées, A-05
RH-031	Non affecté	Alertes PUA anciennes et bénignes, sans rapport avec l'incident (A-01)
PAIE-STA-3 (poste paie)	Non affecté	Copie USB autorisée et tracée (A-17)
Supervision SCADA	Non renseigné	Aucun signe d'atteinte reçu ; hors périmètre des pièces traitées ici

Le périmètre confirmé compromis tient en peu de choses : un compte, un poste, un partage en cours de chiffrement, et une capacité de sauvegarde en ligne neutralisée. C'est resserré, mais c'est aussi ce qui rend l'absence de copie hors ligne vérifiée préoccupante — c'est la seule ligne de ce tableau qui pourrait transformer un incident contenu en perte de données définitive, et elle reste à ce jour non vérifiée plutôt que rassurante.

10 Points ouverts

- **Aucune session VPN à J-3 dans A-02.** A-05 attribue la modification de la politique de rétention (J-3, 01h12) à `svc_oasisnet` — mais les huit sessions de A-02 sautent directement de J-4 à J-1 : aucune connexion VPN n'est journalisée à J-3. Le compte a donc soit agi par un autre canal ce jour-là (persistance déjà posée, accès console direct), soit la modification a été faite depuis une session non couverte par le filtre de l'export. Tant que ce canal n'est pas identifié, l'affirmation « le compte a modifié la politique » reste correcte sur le *qui*, incomplète sur le *comment*.
- **A-05 daté avant son propre contenu.** L'export A-05 est généré à J1 15h15, mais liste un événement à J1 15h28 (dépôts BKP-01/02 injoignables) — postérieur à l'heure de génération affichée. Écart mineur, non expliqué par le dossier reçu ; à signaler plutôt qu'à corriger de son propre chef.
- **Étiquette de jour non concordante à 03h15.** A-01 date la désactivation de l'EDR [J-1] 03:15:22 ; A-05 date la suppression des clichés instantanés J1 03:15. Les deux pointent la même minute d'horloge sur le même poste, et rien n'indique une vraie divergence d'un jour entier — mais les deux pièces n'utilisent techniquement pas la même étiquette, ce qui n'a pas été résolu ici et devrait être demandé à Yassine plutôt que supposé.
- **A-03, non consultée.** Le contexte de A-17 cite « 117,8 Go de l'exfiltration nocturne A-03 », un volume près de dix fois supérieur aux ~12,5 Go que totalise A-02 sur ses huit sessions. Soit A-03 couvre un périmètre plus large que le seul VPN `svc_oasisnet`, soit les deux chiffres ne mesurent pas la même chose. Tant que A-03 n'a pas été demandée et lue, cet écart reste

ouvert — il n'est pas résolu par extrapolation.

- **Vague de tickets du 11h32** non qualifiée : lenteurs, partages et impressions touchant plusieurs services. Elle peut relever de la propagation ou lui être étrangère ; rien dans le dossier ne permet de trancher.
- **Badge (A-14)** et **vidéosurveillance** : demandes à formuler auprès de Yassine, détaillées aux sections 5.3 et 5.4.